Chapter 4: Middleboxes and Security Policies

The 3 Security Components

Network Firewalls

- The History of Firewalls
- What does a Firewall do?
- Configuring Firewalls
- Example: LAN with Mail Server

Stateless Filtering

- Stateful vs. Stateless Firewalls
- Example: LAN with Mail Server (Stateless)
- The ACK flag

Example: LAN with Web Server

Spoofing Protection

Chapter 4: Middleboxes and Security Policies

Common Errors

- Shadowing
- What Firewalls cannot do

Bastion Hosts

Firewall Architectures

- Simple Packet Filter Architecture
- Dual-Homed Host Architecture
- Screened Host Architecture
- Screened Subnet Architecture – DMZ

Intrusion Detection Systems

- Classification
- Examples

Introduction: Network Middleboxes

Definition:

"Any intermediary box, performing functions apart from standard functions of an IP router on the data path between a source host and destination host"

Purposes other than packet forwarding:

- Transformation
- Inspection
- Filtering
- ...

Introduction: Network Middleboxes

RFC 3234[1] defines classification facets:

- Protocol Layer
- Explicit vs. Implicit
- Single-Hop vs. Multi-Hop
- In-Line vs. Call-Out
- Functional vs. Optimizing
- Routing vs. Processing
- Soft-State vs. Hard-State
- Failover vs. Restart

[1] https://tools.ietf.org/html/rfc3234

Introduction: Network Middleboxes
Types

- Firewalls (FW) (FW)
  - Filter traffic based on a set of rules defined by a network administrator
- Intrusion Detection Systems (IDS) (IDS)
  - Monitor traffic and collect data for (offline) analysis for security anomalies
  - Capable of more complex inspection that Firewalls
- Network Address Translators (NAT) (NAT)
  - Replace the source and/or destination IP addresses of packets that traverse them
  - Allow multiple (private) hosts to share a single (public) IP address

⇑ Relevant in Security Contexts ⇑

- Load Balancers (LB)
  - Provide one point of entry to a service, but forward traffic flows to one or more hosts that actually provide the service

Introduction: What does secure mean?

- Definition: Security Policy

  "*A security policy, a specific statement of what is and is not allowed, defines the system's security.*" [Bishop03]

- Definition: Security Mechanisms

  "*Security Mechanisms enforce the policies; their goal is to ensure that the system never enters a disallowed state.*" [Bishop03]

- Examples of Security Mechanisms:
  - IPsec gateways, Firewalls, SSL, . . .

- A system is secure if, started in an allowed state, always stays in states that are allowed.

- The policy defines security, the security mechanisms enforces it.

Chapter 4: Middleboxes and Security Policies

The 3 Security Components

Network Firewalls

Stateless Filtering

Example: LAN with Web Server

Spoofing Protection

Common Errors

Bastion Hosts

Firewall Architectures

Intrusion Detection Systems

The 3 Security Components

- Requirements
  - Define security goals What were those again?
  - Data Integrity, Confidentiality, Availability, Authenticity, Accountability, Controlled Access
  - "*What do we want?*"
- Policy
  - Rules to implement the requirements
  - "*How to get there?*"
- Mechanisms
  - Enforce the policy

The 3 Security Components

- A network admin reports:

  "*Our management wants to ensure that, because of a recent incident, the originators of all internal eMails must now be clearly identifiable. I generated X.509 certificates for all employees and set up their mail clients to always sign their outgoing mails. Unsigned eMails are now dropped by default*"

- Security Requirements:
  Sender accountability of all internal eMails

- Security Policy:
  All eMails must be cryptographically signed

- Security Mechanisms:
  X.509 certificates + signatures, dropping of unsigned eMails by mailserver

Chapter 4: Middleboxes and Security Policies

The 3 Security Components

Network Firewalls

- The History of Firewalls
- What does a Firewall do?
- Configuring Firewalls
- Example: LAN with Mail Server

Stateless Filtering

Example: LAN with Web Server

Spoofing Protection

Common Errors

Bastion Hosts

Firewall Architectures

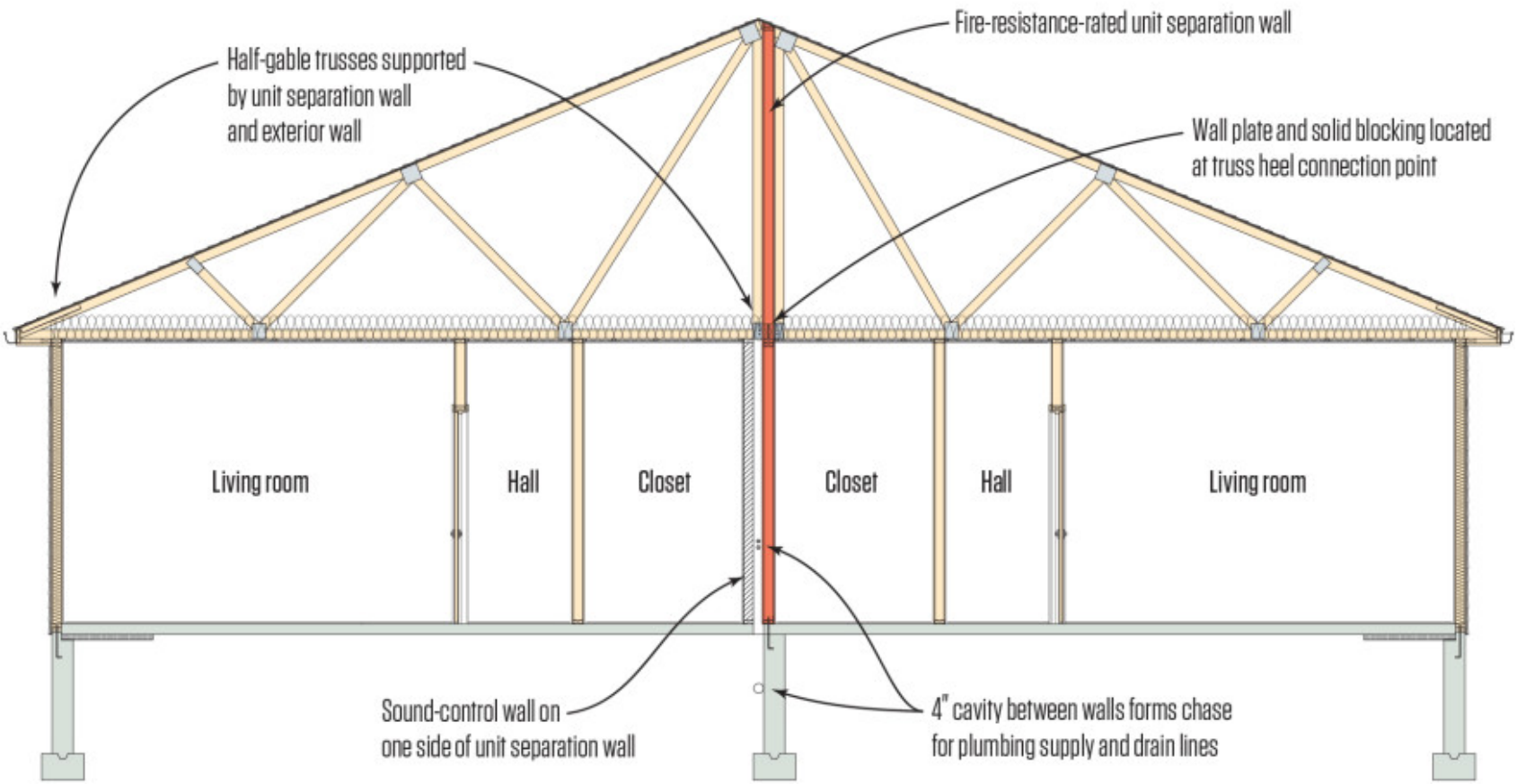
Intrusion Detection Systems

A closer look at policy-heavy security mechanisms

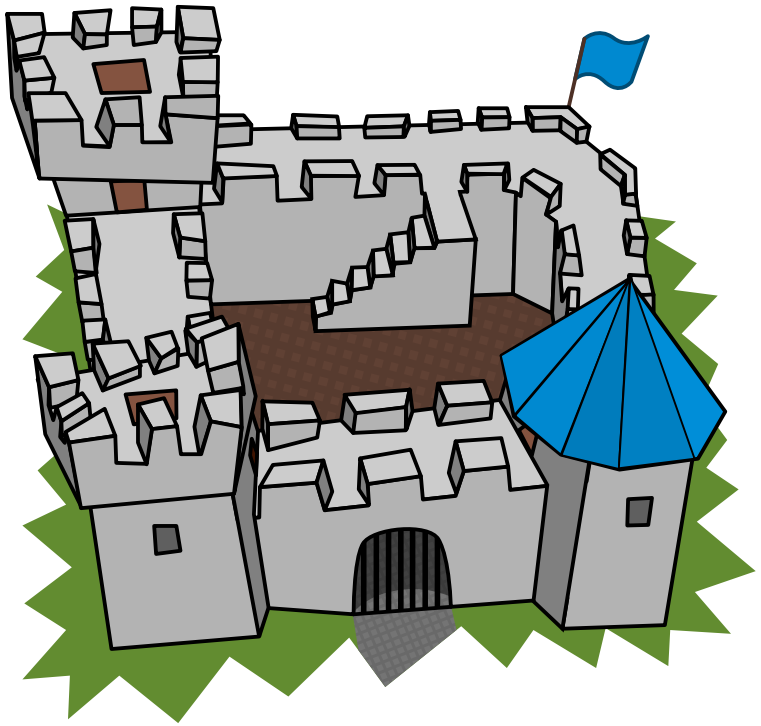
Network Firewalls

The History of Firewalls

- Term comes from Building Construction
- Wall that keeps a fire from spreading from one part of the building to another



The History of Firewalls

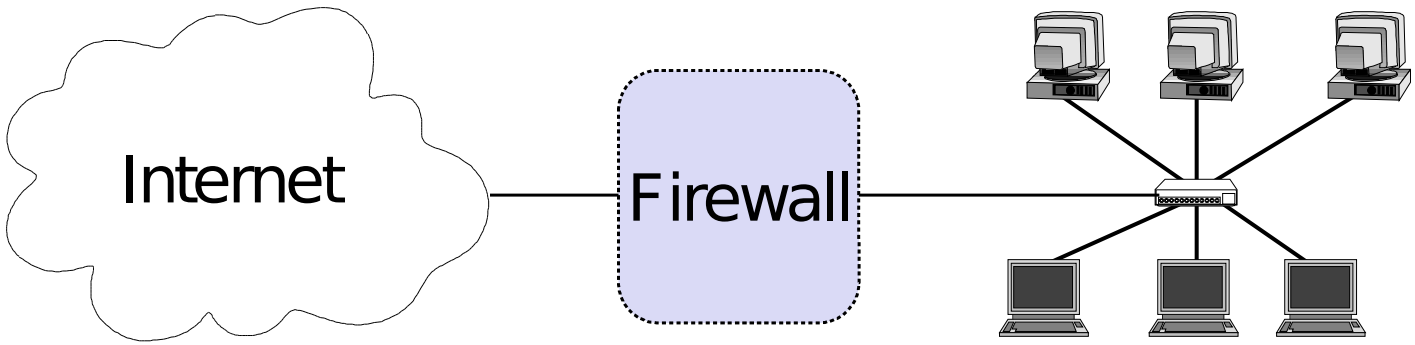


Analogy: The moat of a medieval castle

- Prevents attackers from getting close to other defenses
- Restricts people to enter and leave at one carefully controlled point

Network Firewalls

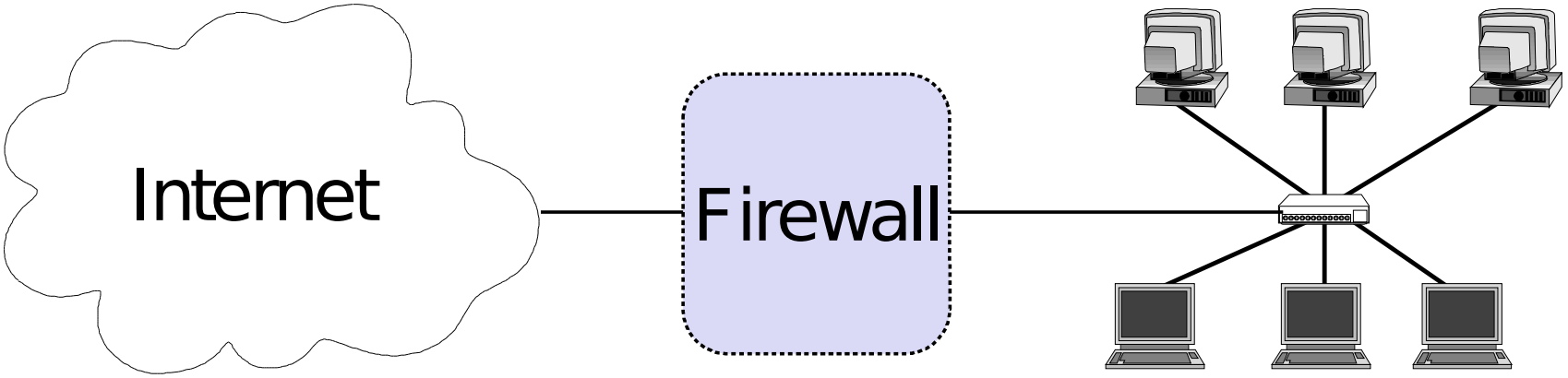
- Network Firewalls



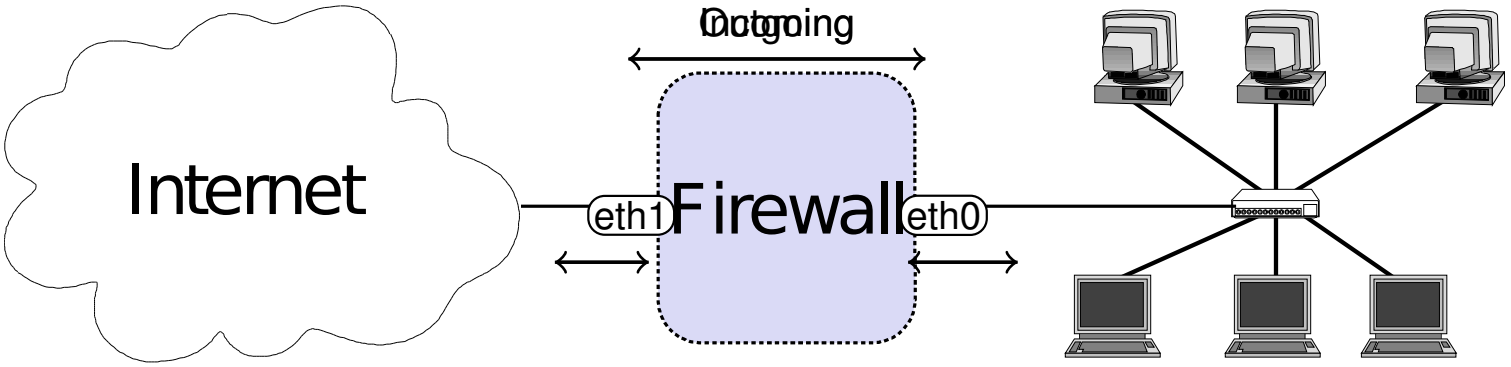
- Do not confuse with host-based firewalls!

Network Firewalls

- Controlled Access at the network level
- Install where a protected subnetwork is connected to a less trusted network
- If not specified otherwise, we assume
  - Firewall is placed between Internet and local network

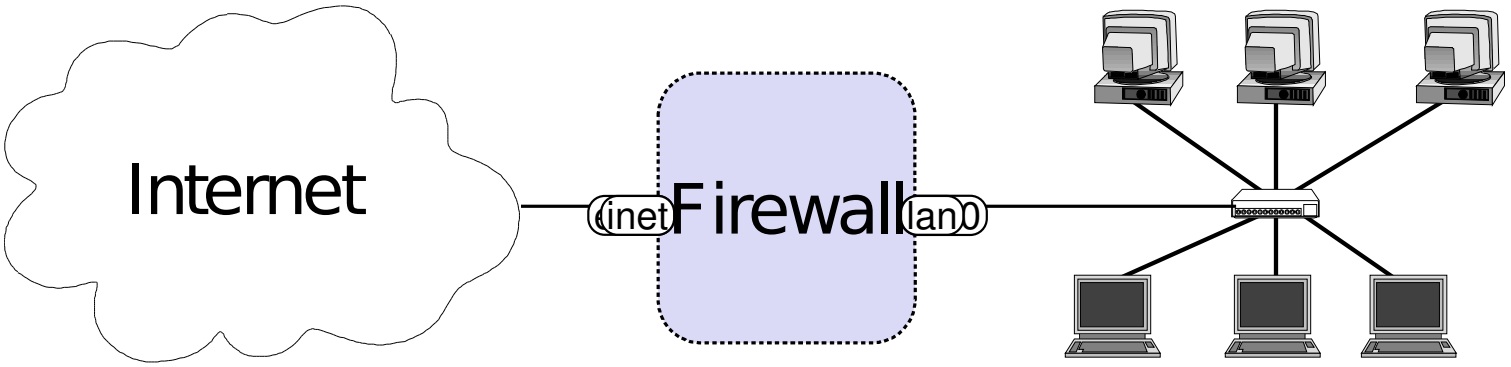


Incoming and Outgoing Packets



- Different views
- View 1 (e.g. by admin of the LAN)
  - Incoming: from the Internet to the local network
  - Outgoing: from the local network to the Internet
- View 2 (e.g. by firewall man page)
  - On each interface, there are incoming and outgoing packets

Incoming and Outgoing Packets



- For convenience:
- `# ip link set eth1 name inet`
- `# ip link set eth0 name lan`

What does a Firewall do?

- By default: nothing!
- Needs to be configured.

Strategies

- Whitelisting
  - Default deny strategy: Everything not explicitly permitted is denied
  - Increased security
- Blacklisting
  - Default permit strategy: Everything not explicitly forbidden is permitted
  - Less hassle with users
- Best Practice: Whitelisting

Example: Strict Whitelisting

Rule	Iface	Src IP	Dst IP	Protocol	Src Port	Dst Port	State	Action
⇒A	lan	192.168.0.0/16	0.0.0.0/0	TCP	> 1023	80	New,Est.	Accept
⇒B	inet	0.0.0.0/0	192.168.0.0/16	TCP	80	> 1023	Est.	Accept
⇒C	*	0.0.0.0/0	0.0.0.0/0	*	*	*	*	Drop

- Policy: Allow outgoing HTTP (TCP port 80), deny the rest
- LAN can initiate outgoing HTTP connections
  - Example: SYN
- The Internet may respond to established connections
  - Example: SYN,ACK
- LAN may use established connections
  - Example: ACK, HTTP GET / HTTP/1.0
- Everything else is prohibited
  - Example: DNS

Configuring Firewalls

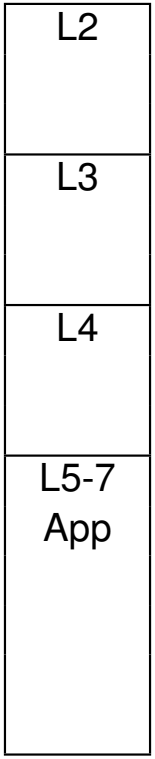
- A firewall is configured by a ruleset
  - Actually: rulelist
- For every packet, the ruleset is processed sequentially until a matching rule is found
- A rule consists of
  - Match condition
  - Action

Rules

- Actions
  - Accept
  - Drop, Reject
  - Log
  - ...
- Match Conditions
  - Incoming interface
  - All l2-l4 packet fields
    - MAC addresses, IP addresses, protocol, ports, flags, ...
  - Stateful matches
    - The firewall tracks connections for you
    - e.g. with the IP-5-tuple
  - Further advanced conditions
    - rate limiting, locally tagged packets, ...

Details on Packet Fields

- Link Layer (l2) – Ethernet
  - EtherType
    - Usually: `0x0800` (IPv4)
    - Handle other EtherTypes: e.g. Drop `0x86DD` (IPv6)
  - Ethernet MAC Address
    - Easily spoofable!
    - `# ifconfig eth0 hw ether de:ad:be:ef:de:ad`
- Network Layer (l3) – IPv4
  - IP addresses
  - Transport protocol
    - TCP, UDP, ICMP, ...
  - Flags: IP fragment
  - Options: E.g. source routing
    - Please drop source routing!



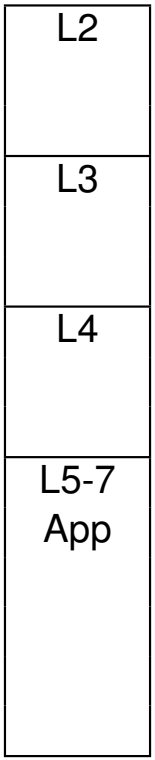
Details on Packet Fields

- Transport Layer (l4) – TCP/UDP
  - Ports
    - Determine the sending / receiving application.
    - Limited degree of confidence
    - Well-Known Ports (0-1023):

      E.g. HTTP (80), DNS (53), HTTPS (443).
    - Registered Ports (1024-49151)

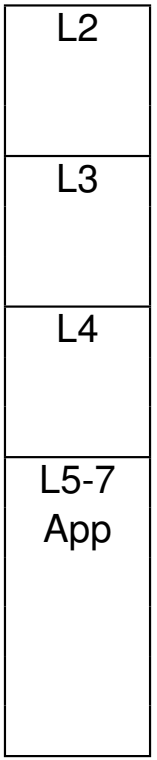
      E.g. IRC (6667), BitTorrent tracker (6969), ...
    - Ephemeral Ports (49152-65535):

      ports meant to be used temporarily by clients.
  - Flags
    - ACK: set in every segment of a connection but the very first
    - SYN: only set in the first two segments
    - RST: ungraceful close of a connection



Details on Packet Fields

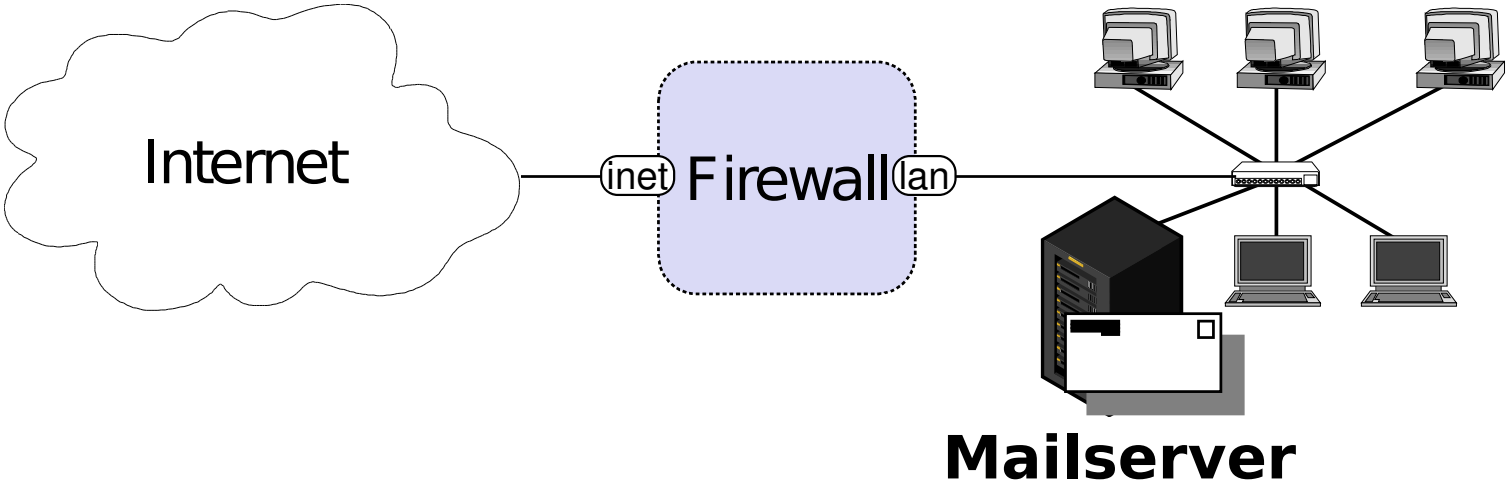
- Application Protocol (l5-7)
  - Deep Packet Inspection
  - usually not done by firewalls
  - easier to realize in proxy systems



Stateful Matching

- Arriving packets may generate state in the firewall.
- Connection tracking with the IP-5-tuple
  - (Src IP, Dst IP, Proto, Src Port, Dst Port)
- States of a connection
  - NEW: First packet of a connection
  - ESTABLISHED: All following packets
- Optional State tracking (depending on your firewall)
  - TCP sequence and ack numbers, and flags
  - ICMP sequence numbers and request/response tracking
- Note: UDP connection tracking is always an approximation!
  - Example: Attacker sends spoofed DNS replies in the hope that victim might accept one as an answer to a previous DNS query.

Example: LAN with Mail Server



- Security policy
  - Incoming and outgoing email should be the only allowed traffic into and out of a protected network
  - Email is SMTP, TCP port 25
  - Anyone in the internal network can send out emails to arbitrary mailservers in the Internet
  - Incoming emails must only arrive at the Mailserver

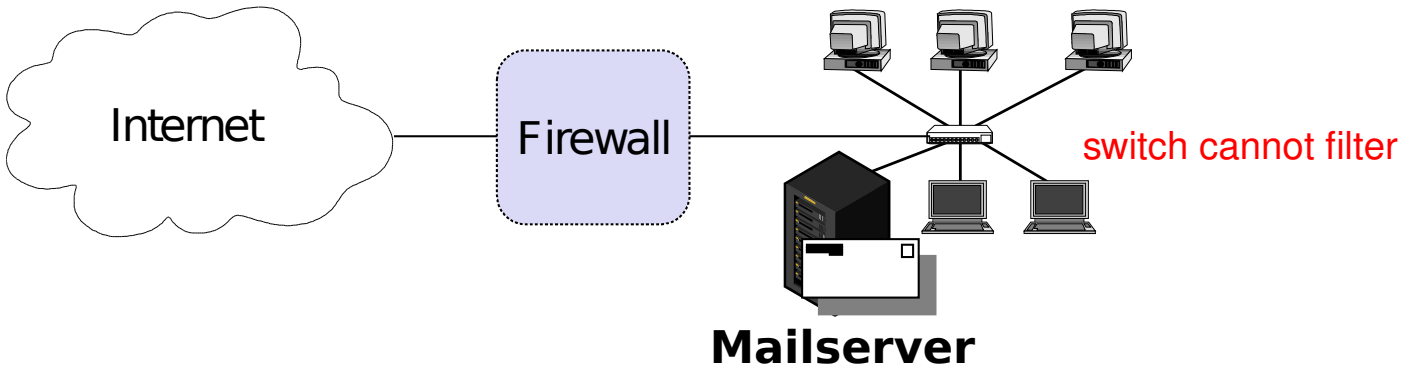
Example: LAN with Mail Server

Rule	Iface	Src IP	Dst IP	Protocol	Src Port	Dst Port	State	Action
⇒A	inet	external	mailserver	TCP	*	25	New	Accept
⇒B	lan	internal	external	TCP	*	25	New	Accept
⇒C	*	*	*	TCP*	*	*	Est.	Accept
⇒D	*	*	*	*	*	*	*	Drop

- Rule A allows new incoming SMTP (TCP port 25) connections to establish a connection with the internal Mailserver
- Rule B allows establishing SMTP connection from the internal network to the Internet
- Rule C allows all established connections. Only with rule A and B, a connection can be in the ESTABLISHED state.
- Rule D denies the rest (whitelisting)
- Any difference? No, only TCP can get into Est. state!

Example: LAN with Mail Server
Discussion

- Can we do better?
  - Internal hosts can establish connections to the Mailserver
- Can we prevent his?
  - No! The firewall cannot intercept these connections, attributable to the network topology.



- This subverts the security policy
- Simple fix 1: Check the security requirements, update the policy
- Simple fix 2: Replace the internal switch by a second firewall

Example: LAN with Mail Server
Possible Weaknesses

- Assume we are `tcpdump`ing on the firewall.
- In the range of the well-known ports, is Mailserver on TCP dest. port 25 (incoming) the only entity which can exchange traffic with the Internet?
  - No!
  - Assume an internal host sends out a TCP packet with source and destination port 25 to `shadymail.example`
  - Rule B establishes a new state in the firewall.
  - Now, for `shadymail.example`, using source port 25, the internal host is reachable on the well-known port 25!
  - Fix: make sure that only source ports > 1023 are allowed to establish a connection

Example: LAN with Mail Server

Rule	Iface	Src IP	Dst IP	Protocol	Src Port	Dst Port	State	Action
A	inet	external	mailserver	TCP	*> 1023	25	New	Accept
B	lan	internal	external	TCP	*> 1023	25	New	Accept
C	*	*	*	*	*	*	Est.	Accept
D	*	*	*	*	*	*	*	Drop

Example: LAN with Mail Server
Tuning

- Firewall rules are matched sequentially
- Few packets will establish a new connection
- Many packets will use an established connection
- Move rule C to the front
- A connection can only be in ESTABLISHED state by rule A and B, the transformation preserves the semantics

Rule	Iface	Src IP	Dst IP	Protocol	Src Port	Dst Port	State	Action
C	*	*	*	*	*	*	Est.	Accept
A	inet	external	mailserver	TCP	> 1023	25	New	Accept
B	lan	internal	external	TCP	> 1023	25	New	Accept
D	*	*	*	*	*	*	*	Drop

Best Practice: Put the ESTABLISHED rule first

- Performance
  - Our firewall (September 2014)
  - $>$ 15 billion packets, 19+ Terabyte data since the last reboot
  - $>$ 95% of all packets match the ESTABLISHED rule
- Management
  - First rule: “enable stateful matching”
  - All following rules: Access control list

Chapter 4: Middleboxes and Security Policies

The 3 Security Components

Network Firewalls

Stateless Filtering

- Stateful vs. Stateless Firewalls
- Example: LAN with Mail Server (Stateless)
- The ACK flag

Example: LAN with Web Server

Spoofing Protection

Common Errors

Bastion Hosts

Firewall Architectures

Intrusion Detection Systems

Stateless Filtering

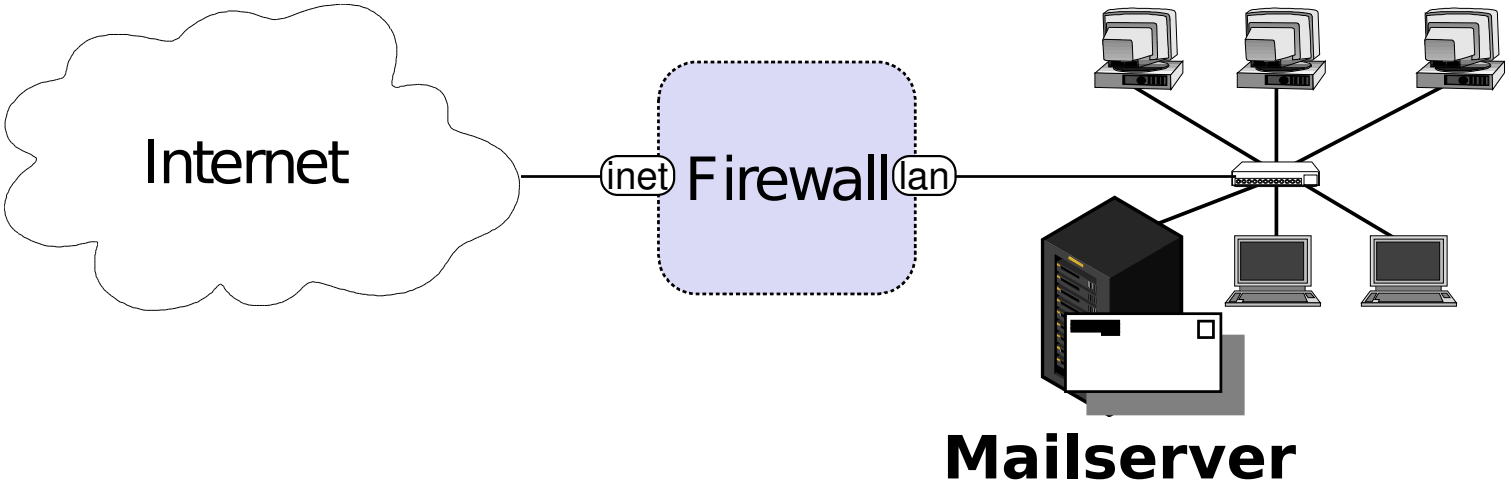
- Only operates on the rules and each individual packet.
- No state information is generated when processing a packet.
- Keeping state is expensive and needs fast memory.
- Only few rules: stateless filtering may be faster
  - $\mathcal{O}$(# rules)
- Many rules: stateful filtering may be faster
  - Majority matches first rule, $\mathcal{O}(1)$ lookup
  - Possible DOS attacks
    - sending packets which need $\mathcal{O}$(# rules) processing
    - Filling the state table
- Many network boxes have stateless firewall features embedded
  - Router access lists
  - Some switches
  - ...

Stateful vs. Stateless Firewalls

Rule of thumb:

- Stateless firewalls are more complex to configure
- Which makes configuration errors more likely
- Whenever possible, go for the stateful firewall!
- Hardware is cheap

Example: LAN with Mail Server (Stateless)



- Security policy
  - Incoming and outgoing email should be the only allowed traffic into and out of a protected network
  - Email is SMTP, TCP port 25
  - Anyone in the internal network can send out emails to arbitrary mailservers in the Internet ~~in the Internet~~
  - Incoming emails must only arrive at the Mailserver

Example: LAN with Mail Server (Stateless)

Rule	Iface	Src IP	Dst IP	Protocol	Src Port	Dst Port	Ack	Action
$\Rightarrow A_1$	inet	external	mailserver	TCP	*	25		Accept
$\Rightarrow A_2$	lan	mailserver	external	TCP	*	> 1023		Accept
$\Rightarrow B_1$	lan	internal	external	TCP	*	25		Accept
$\Rightarrow B_2$	inet	external	internal	TCP	*	> 1023		Accept
$\Rightarrow C$	*	*	*	*	*	*		Drop

- Rule A_1 allows incoming email to enter the network.
  Rule A_2 allows the mailserver's answers to exit the network.
- Rules B_1 and B_2 are analogous for outgoing email.
- Rule C denies all other traffic.

Example: LAN with Mail Server (Stateless)
Discussion – Problems

Rule	Iface	Src IP	Dst IP	Protocol	Src Port	Dst Port	Ack	Action
A_1	inet	external	mailserver	TCP	*	25		Accept
A_2	lan	mailserver	external	TCP	*	> 1023		Accept
B_1	lan	internal	external	TCP	*	25		Accept
B_2	inet	external	internal	TCP	*	> 1023		Accept
C	*	*	*	*	*	*		Drop

- Which problems do you see?
  - Rule B_2 allows incoming connections to the network on port numbers > 1023
  - Rule A_2 allows the mailserver to respond to port numbers > 1023
  - We do not differentiate between new or established connections
  - Conclusion: The firewall is not configured well; especially the mailserver is endangered

Example: LAN with Mail Server (Stateless)

Discussion – A possible attack

Rule	Iface	Src IP	Dst IP	Protocol	Src Port	Dst Port	Ack	Action
A_1	inet	external	mailserver	TCP	*	25		Accept
A_2	lan	mailserver	external	TCP	*	> 1023		Accept
B_1	lan	internal	external	TCP	*	25		Accept
B_2	inet	external	internal	TCP	*	> 1023		Accept
C	*	*	*	*	*	*		Drop

- Ruleset does not block the X11-protocol for the Mailserver, which allows reading/manipulating the display and keystrokes
  - X11-server listens at port 6000, clients use port numbers > 1023
  - Incoming X11-request is not blocked (Rule B_2)
  - And neither is any answer (Rule A_2)

Example: LAN with Mail Server (Stateless)
Fix # 1

Rule	Iface	Src IP	Dst IP	Protocol	Src Port	Dst Port	Ack	Action
A_1	inet	external	mailserver	TCP	> 1023	25		Accept
A_2	lan	mailserver	external	TCP	25	> 1023		Accept
B_1	lan	internal	external	TCP	> 1023	25		Accept
B_2	inet	external	internal	TCP	25	> 1023		Accept
C	*	*	*	*	*	*		Drop

- Fixing the flaw: include source ports
  - Rule B_2: only allow incoming traffic from a SMTP server (port 25) to ports > 1023.
  - Rule A_2: only allows outgoing traffic from a SMTP server (port 25) to ports > 1023
  - $\longrightarrow$ traffic from internal X-clients or -servers blocked
- Fix the attack: use non-standard port 25 for attacking X-client
  - Firewall will let this traffic pass
- Fix the new flaw: Only permit traffic from port 25 if it is related to a connection established by a client

The ACK flag

- ACK flag: approximate the state of TCP connections
- ACK flag is set in every TCP segment but the first one
  - C.f. TCP 3-way handshake
- Rule of thumb: ACK $\approx$ not NEW
- Assumes that information in packets can be trusted
  - Attacker could send SYN/ACK as initial packet
  - Passes the firewall.
  - Hosts will ignore it if they don't have a flaw in their network stack.
- Protocols such as UDP don't have state information
  - Not possible to differentiate between initiator and responder.
  - UDP has no ACK field: Always set ACK to *

The ACK flag
Fix # 2

Rule	Iface	Src IP	Dst IP	Protocol	Src Port	Dst Port	Ack	Action
A_1	inet	external	mailserver	TCP	> 1023	25	*	Accept
A_2	lan	mailserver	external	TCP	25	> 1023	Yes	Accept
B_1	lan	internal	external	TCP	> 1023	25	*	Accept
B_2	inet	external	internal	TCP	25	> 1023	Yes	Accept
C	*	*	*	*	*	*	*	Drop

- Checking whether the TCP ACK flag is set
- Permits establishing new connections between mail clients and SMTP servers (port 25)
- SMTP servers (port 25) cannot establish new connections

The 3 Security Components

Network Firewalls

Stateless Filtering

Example: LAN with Web Server

Spoofing Protection

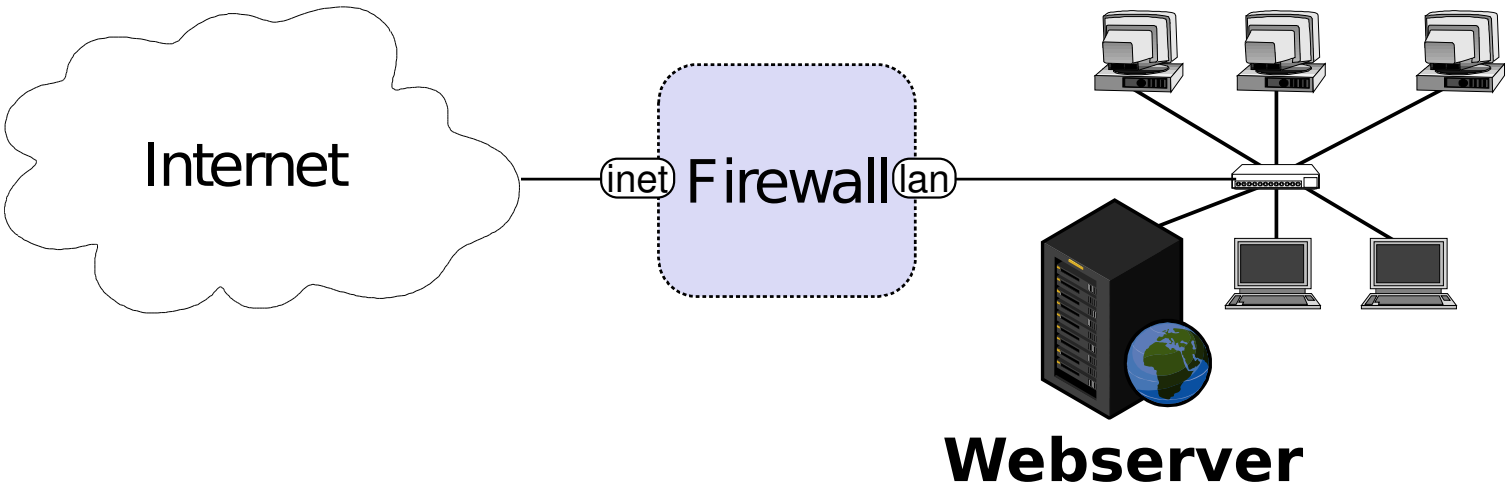
Common Errors

Bastion Hosts

Firewall Architectures

Intrusion Detection Systems

Example: LAN with Web Server



- Security policy
  - Allow HTTP traffic initiated by external hosts to webserver
  - Allow internal hosts to initiate HTTP and DNS
    - HTTP: TCP port 80
    - DNS: UDP port 53
  - Do not allow other communication, in particular no communication initiated by external hosts to the local hosts other than the webserver.

Stateful Firewall

Rule	Iface	Src IP	Dst IP	Protocol	Src Port	Dst Port	State	Action
A	*	*	*	*	*	*	Est.	Accept
B	inet	external	webserver	TCP	> 1023	80	New	Accept
C	lan	internal	external	TCP	> 1023	80	New	Accept
D	lan	internal	external	UDP	> 1023	53	New	Accept
E	*	*	*	*	*	*	*	Drop

- First rule?
- Allow HTTP traffic initiated by external hosts to webserver?
- Allow internal hosts to initiate HTTP? and DNS?
- Do not allow other communication ... ?

Stateless Firewall

Rule	Iface	Src IP	Dst IP	Protocol	Src Port	Dst Port	Ack	Action
B_1	inet	external	webserver	TCP	> 1023	80	*	Accept
B_2	lan	webserver	external	TCP	80	> 1023	Yes	Accept
C_1	lan	internal	external	TCP	> 1023	80	*	Accept
C_2	inet	external	internal	TCP	80	> 1023	Yes	Accept
D_1	lan	internal	external	UDP	> 1023	53	-	Accept
D_2	inet	external	internal	UDP	53	> 1023	-	Accept
E	*	*	*	*	*	*	*	Drop

- A first rule comparable to the stateful case? No.
- Allow HTTP traffic initiated by external hosts to webserver?
- Allow internal hosts to initiate HTTP? and DNS?
- Do not allow other communication ... ?

The 3 Security Components

Network Firewalls

Stateless Filtering

Example: LAN with Web Server

Spoofing Protection

Common Errors

Bastion Hosts

Firewall Architectures

Intrusion Detection Systems

Spoofing Protection

- Outgoing (to the Internet)
  - Only allow source IPs which belong to you
  - Don't be an operator who facilitates spoofed DOS attacks to the Internet!
- Incoming (from the Internet)
  - Only allow 'valid' source IPs
  - For a varying definition of 'valid'
  - IPs which belong to you are not valid
  - Local and special purpose IPs are not valid
  - Rule of thumb: UNIV $\setminus$ (Your IPs $\cup$ Special Purpose IPs)
- Spoofing must always be filtered close to the source. Why?

Spoofing Protection
Example

- Assume your institution owns 131.159.20.0/24

Rule	Iface	Src IP	Dst IP	Action
A	lan	! 131.159.20.0/24	*	Drop
B	inet	131.159.20.0/24	*	Drop
B	inet	192.168.0.0/16	*	Drop
B	inet	10.0.0.0/8	*	Drop
B	inet	172.16.0.0/12	*	Drop
B	*	*	*	Accept

- There are more addresses you might want to drop [RFC6890]

Automatic Spoofing Protection

- The Linux kernel offers some spoofing protection for free
- `/proc/sys/net/ipv4/conf/all/rp_filter`
- If a packet arrives at interface *i*, the kernel checks
  - Is the source IP of the packet reachable through *i*
  - If not, drop the packet
- Only considers local routing and interface configuration

Chapter 4: Middleboxes and Security Policies

The 3 Security Components

Network Firewalls

Stateless Filtering

Example: LAN with Web Server

Spoofing Protection

Common Errors

- Shadowing
- What Firewalls cannot do

Bastion Hosts

Firewall Architectures

Intrusion Detection Systems

Common Errors

- How is your firewall management interface reachable?
  - From the Internet? From the complete internal network?
  - Via telnet? Via UPnP?
- What is allowed over the Internet?
  - NetBIOS? NFS? RPC? Telnet?
  - Other ICMP than Unreachable, Fragmentation Needed, TTL Exceeded, Ping?
  - IP header options?
- IPv4 and IPv6?
  - Are the rule sets compliant?
- Outbound rule ANY? (c.f. spoofing)
  - Even private IP ranges or IP ranges that don't belong to you?
- Policy's vs. Firewalls understanding of Inbound and Outbound?
  - If `eth0` is your internal interface and the firewall says inbound on eth0, policy might say outbound.

Shadowing

“ Shadowing refers to the case where all the packets one rule intends to deny (accept) have been accepted (denied) by preceding rules” [fireman06]

Rule	Iface	Src IP	Dst IP	Action
A	*	*	192.168.0.0/16	Accept
B	*	*	192.168.42.0/24	Drop

- Rule B will never match!

Another Example

- No spoofing for the following networks:
  - eth0 $\longleftrightarrow$ 10.0.0.0/16
  - eth1 $\longleftrightarrow$ 10.1.0.0/16
  - eth2 $\longleftrightarrow$ 10.2.0.0/16
- Accessible by all three networks: 10.1.1.1

Rule	Iface	Src IP	Dst IP	Action
A	eth0	! 10.0.0.0/16	*	Drop
B	eth1	! 10.1.0.0/16	*	Drop
C	*	*	10.1.1.1	Accept
D	eth2	! 10.2.0.0/16	*	Drop
E	*	*	*	Drop

- Correct?
- Anyone at eth2 can send spoofed packets to 10.1.1.1
- Rule D is partly shadowed

What Firewalls cannot do

A firewall

- cannot protect against malicious insiders
- cannot protect against connections that don’t go through it
- cannot protect against completely new threats
- cannot fully protect against viruses
- does not perform cryptographic operations, e.g. message authentication
- cannot set itself up correctly

The 3 Security Components

Network Firewalls

Stateless Filtering

Example: LAN with Web Server

Spoofing Protection

Common Errors

Bastion Hosts

Firewall Architectures

Intrusion Detection Systems

Bastion Hosts

- Definition:

  "*A bastion host is a host that is more exposed to the hosts of an external network than the other hosts of the network it protects.*"

- A bastion host may serve for different purposes:
  - Packet filtering
  - Providing proxy services
  - A combination of both

Securing Bastion Hosts

- Keep it simple
- Prepare for the bastion host to be compromised
- Connect in such a way that it cannot sniff internal traffic
- Extensive and tamper-resistant logging
- Reliable hardware configuration and physically secure location
- Disable ssh password login (only public key login)
- Disable user accounts
- Monitor the machine closely (reboots, usage / load patterns, etc.)
- Regular backups

Chapter 4: Middleboxes and Security Policies

The 3 Security Components

Network Firewalls

Stateless Filtering

Example: LAN with Web Server

Spoofing Protection

Common Errors

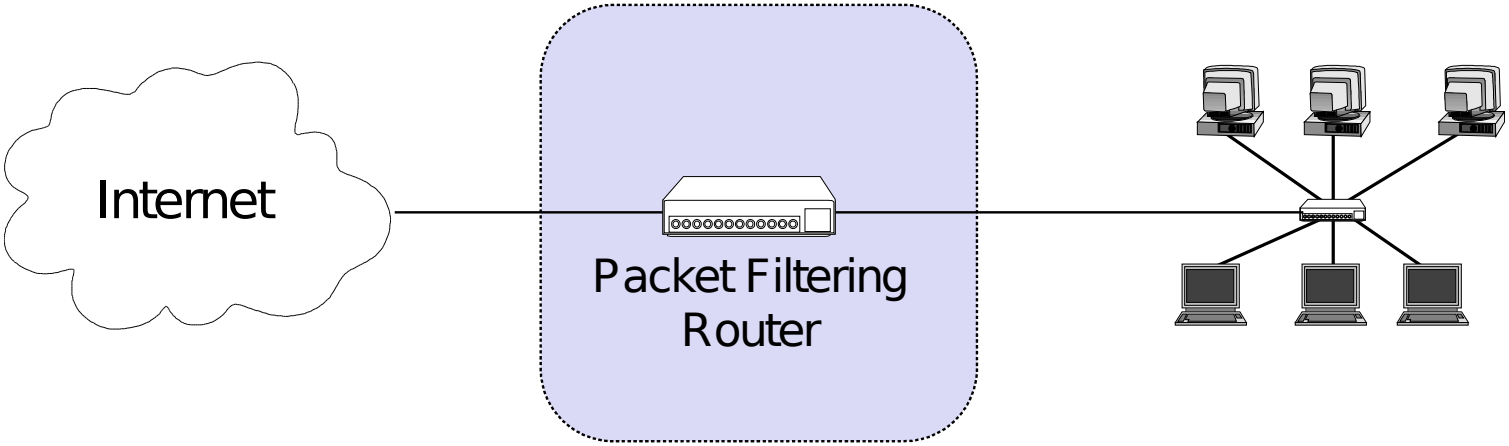
Bastion Hosts

Firewall Architectures

- Simple Packet Filter Architecture
- Dual-Homed Host Architecture
- Screened Host Architecture
- Screened Subnet Architecture – DMZ

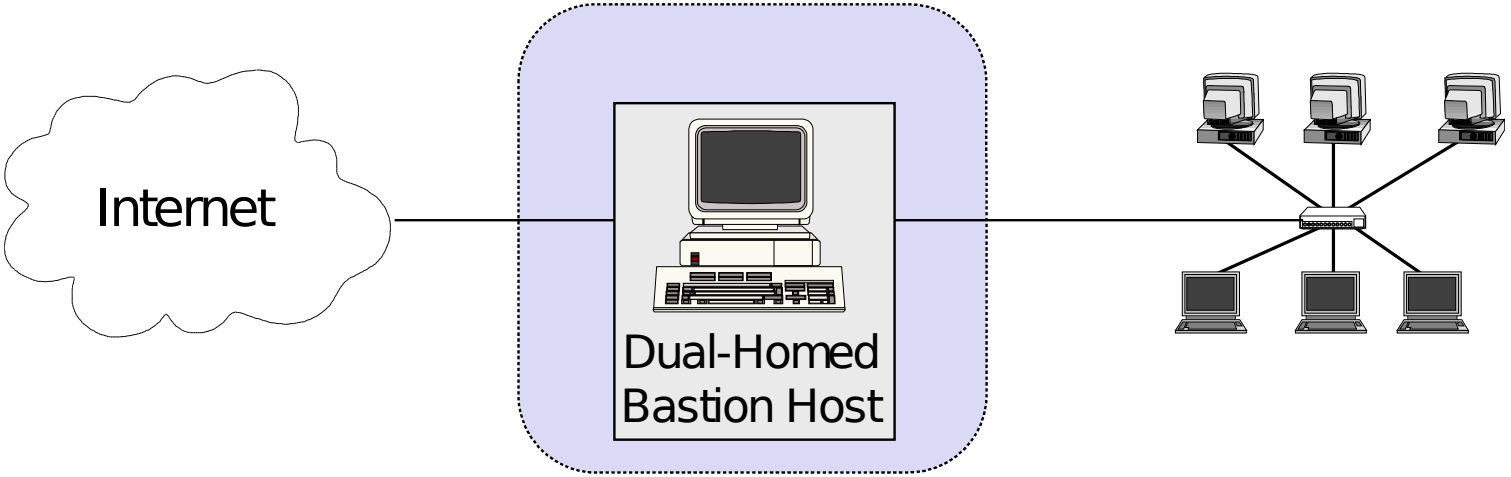
Intrusion Detection Systems

Simple Packet Filter Architecture



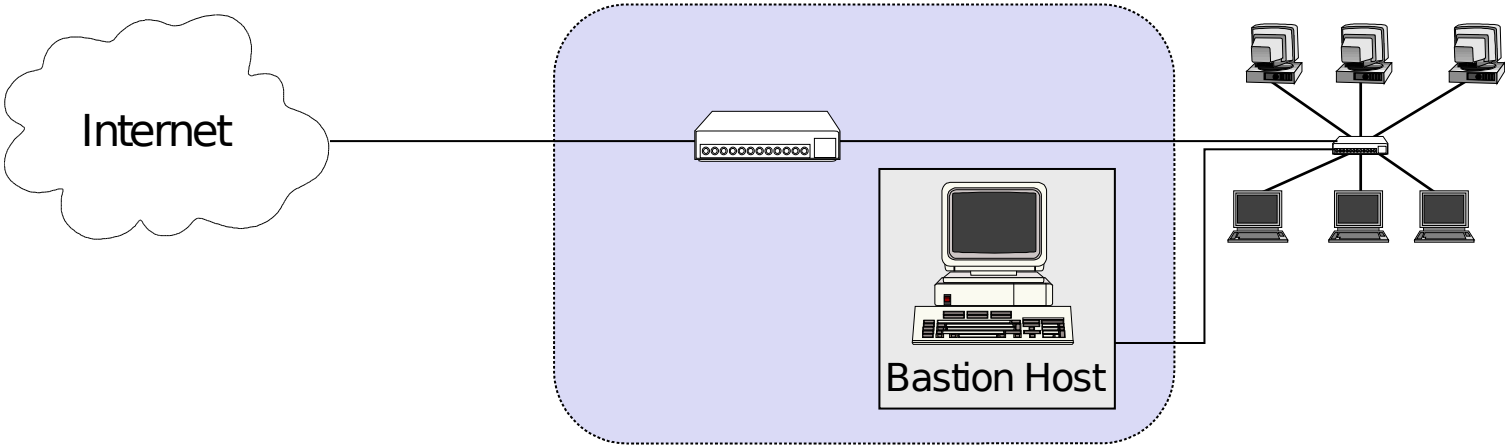
- A packet filtering router or firewall with two interfaces

Dual-Homed Host Architecture



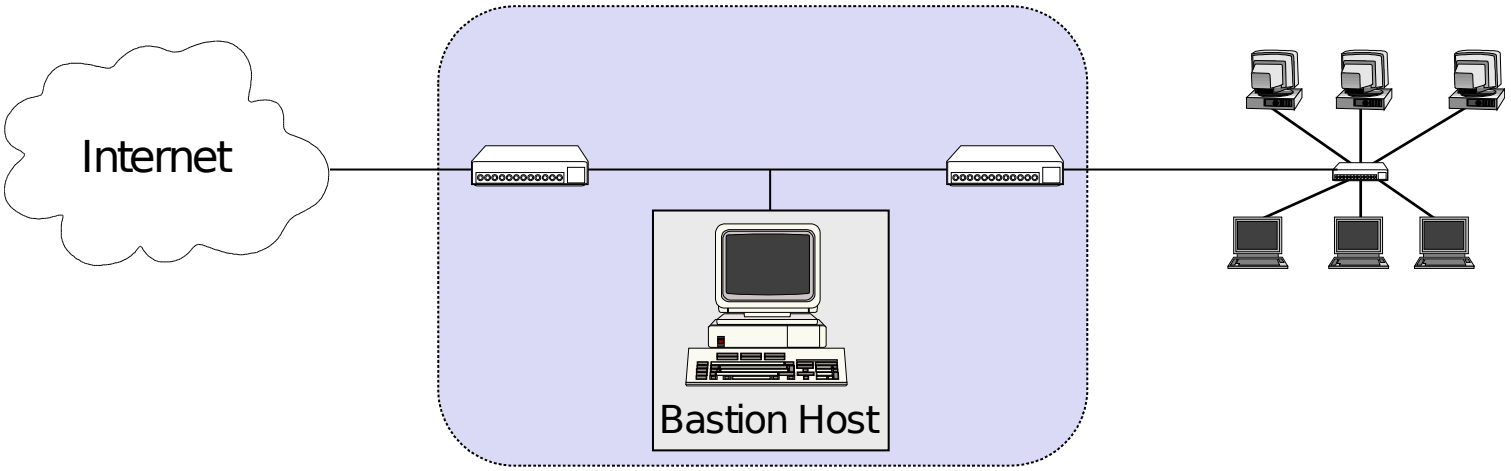
- Dual-Homed: Host is part of two networks (has two NICs)
- Bastion Host is Firewall + Application Proxy
- Drawbacks
  - Bastion Host is bottleneck
  - Compromised Bastion Host is worst-case scenario

Screened Host Architecture



- Packet filter protects network and Bastion Host
- Bastion Host is Proxy (may be accessible from the Internet)
  - Compromised Bastion Host compromises the internal network
- If you have a home server and configured port-forwarding on your router, this is probably your architecture

Screened Subnet Architecture – DMZ



- Demilitarized Zone (DMZ): perimeter network
- Hosts Bastion Host (Proxy) and publicly accessible servers
- Second packet filter in case they are compromised
  $\longrightarrow$ Protection for the internal network
- Requires two firewalls or one firewall with at least 3 NICs

Literature

- M. Bishop. *What is computer security?* Security and Privacy, 2003
- L. Yuan, H. Chen, J. Mai, C. Chuah, Z. Su, P. Mohapatra. *FIREMAN: a toolkit for firewall modeling and analysis.* Security and Privacy, 2006
- A. Wool. *A quantitative study of firewall configuration errors.* Computer, IEEE 37(6), 2004, pp. 62 – 67
- `man iptables`
- `man iptables-extensions`
- J. Engelhardt, *Towards the perfect ruleset.* May 2011. `http://inai.de/documents/Perfect_Ruleset.pdf`
- M. Cotton, L. Vegoda, R. Bonica, and B. Haberman, *SpecialPurpose IP Address Registries.* RFC 6890
- *BCP38*, `http://www.bcp38.info/`

Chapter 4: Middleboxes and Security Policies

The 3 Security Components

Network Firewalls

Stateless Filtering

Example: LAN with Web Server

Spoofing Protection

Common Errors

Bastion Hosts

Firewall Architectures

Intrusion Detection Systems

- Classification
- Examples

Intrusion Detection Systems

Why is Intrusion Detection hard?

Background: Binary Classification

	Attack	**No Attack**
Alarm Raised	True Positive 99.9999%	False Positive 0.0001%
No Alarm Raised	False Negative 0.0001%	True Negative 99.9999%

How would you describe that system?

- Excellent
- Fantastic
- Very good
- **Total disaster, so sad!**

- Assume the Munich Scientific Network handles about 1 million packets per second (10Gbit/s).
- This will generate 1 false positive event per second!

Intrusion Detection Systems

Why would we need Intrusion Detection Systems?

- Most systems have vulnerabilities
  - Vulns may be known or unknown
  - Vulns may potentially be used to carry out attacks
- Attacks can be detected by being aware of
  - Unusual or suspicious actions
  - Unusual or suspicious alterations of stored information
- What do we want to detect?
  - Intrusion preambles (probes)
  - Intrusion accesses from the outside
  - Abusive behaviours from the inside

Intrusion Detection Systems
Definitions

- Intrusion
  - Compromise of a defined Security Requirement
  - Manifestation through e.g. unauthorized or abnormal activities or data
- Intrusion Detection System
  - Software that has the function to detect and identify intrusions
  - Not all IDS take countermeasures

Optional extension:

- Honeypot
  - Closely monitored computing resource which is intended to be compromised
  - Allows for in-depth examination of conducted exploits
  - Provides early-warning about new attack trends
  - Distracts adversaries from more valuable targets
  - Can be used as origin for further attacks

Classification

Detection Method	Misuse detection	
	Anomaly Detection	
Data Source	Network-based	$\Rightarrow$ *Hybrid*
	Host-based	
Detection Delay	Real-time	
	A posteriori	
Reaction	Passive	
	Active	
Analysis	Individual	
	Cooperative	

Misuse Detection

Idea:

- Store signatures of attacks in a database
- Monitor traffic for signatures
- Frequently update signature database

Example rule definition in the Snort IDS:

```
alert tcp $HOME_NET any -> any 9996 \

(msg:'Sasser ftp script to transfer up.exe'; \
 content:"|5F75702E657865|"; depth:250; flags:A+; classtype: misc-activity; \
 sid:1000000; rev:3)
```

$\boxed{5F75702E657865}$ $\Rightarrow$ This must be the Sasser worm!

$\boxed{5F75702E657864}$ $\Rightarrow$ This must be harmless traffic!

Detection Method

Anomaly Detection

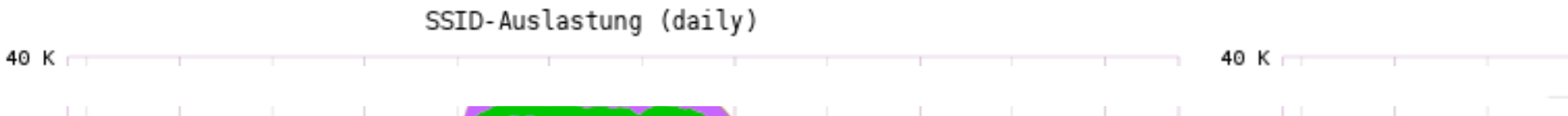
Idea:

- Model a *normal* or *expected* state of a system
- Compare the current state to the model
- Raise alarm if the current state differs more than a certain threshold

$\Rightarrow$

Exemplary Model:

- Average: $12.7k$
- Threshold: $10k < x < 15k$



Anomaly Detection - Difficulties

Diurnal patterns

- Time of day (very few users at night)
- Day of week (very few users on weekends)
- Time of year (fewer users during semester break)
- *Random* events (public holidays, festivities...)

Long-term patterns

- Number of users will grow over time
- TUM student count roughly doubled in the past 10 years

It is difficult to build a well-functioning anomaly detection

- Real-word use typically limited to narrow edge cases
- Assume the highest observed peak to be $42k$
- Consider the rule $\boxed{\text{WiFi users} > 50k}$

Comparing the Detection Methods:

I. Misuse Detection

- Knowledge-driven
- Searches for predefined attack signatures

+ Very efficient detection
+ Less false positives

– Only detects known attacks
– More false negatives

II. Anomaly Detection

- Behaviour-driven
- Based on Heuristics or Machine Learning

+ Able to detect new attacks
+ Collected data can be utilized for definition of new attack signatures

– Typically plenty of training required
– Heuristics threshold definition is complex
– More false positives

Data Source

Where does the data come from?

I. Network-based IDS

- Performs analysis on network packets

+ Small amount of sensors are able to monitor a large network
+ Little impact to networking performance
+ Hard to trace for attackers

– Large data amounts need to be processed
– Difficult to install in non-shared networks
– Cannot analyse encrypted data
– Difficult to track all connection state in the network

II. Host-based IDS

- Analyses data from individual systems

+ Can detect attacks, which are not affecting the network stack
+ Able to function in environments with encrypted data

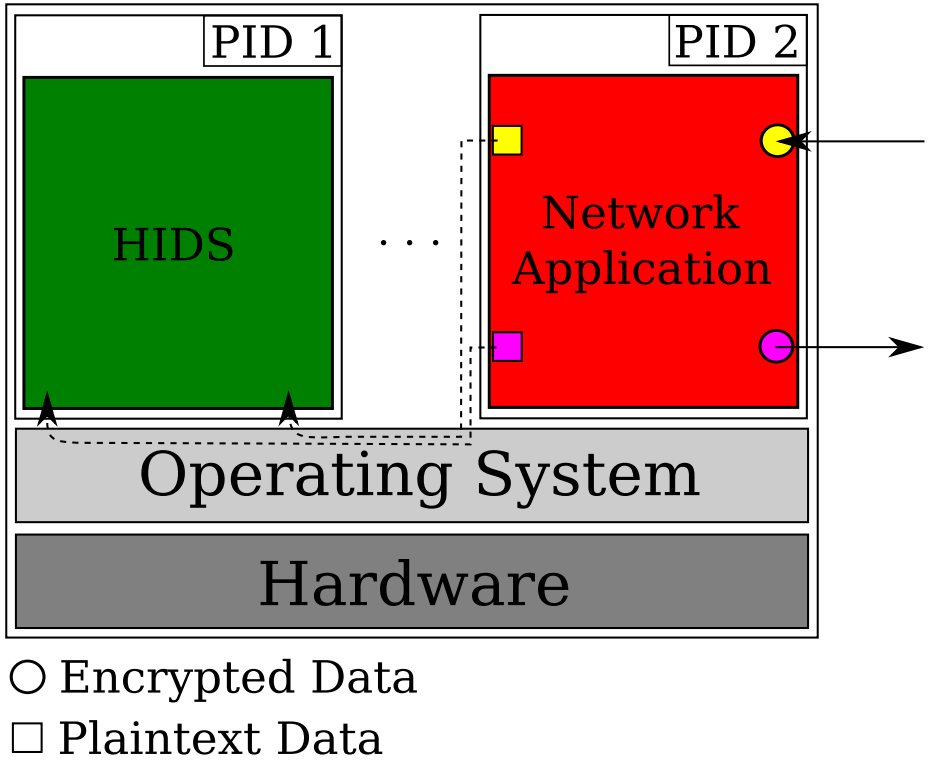
⇒ How?

– Hard to manage
– Can be deactivated on host compromise
– Degrades operating host performance

Digression: Intrusion Detection on end-to-end encrypted communication

How does an HIDS detect malicious data in encrypted traffic?

- Many applications encrypt their traffic
- Plaintext is handled at some point
- Even with end-to-end crypto
- Idea:
  Read communication data from process memory while in plaintext form [Kilic2015]
- Realisation through e.g. `ptrace`



Data Source

Which attacks can different IDS detect?

I. Network-based IDS

- Unauthorized network access
- Reconnaissance (e.g. network scans)
- Abuse of bandwidth resources (e.g. DoS)
- Network protocol violations
  - Improperly formatted packets
  - Spoofing-Attempts (e.g. ARP-Spoofing)
  - Actual exploit payloads
  - ...

II. Host-based IDS

- Privilege Abuse
- Accidentally assigned privileges
- Account compromise
- Access and modification of critical data
- Information leakage

Detection Delay

When is the information processed?

- Real-time detection
  - Data and control flows are intercepted
  - Information processing while target system is running
  - Short detection time
  - Interferes with system performance
- *A posteriori*
  - Information is logged
  - Processing and analysis conducted later
  - Longer detection time
  - Easily parallelized

Analysis

How does the system react to an attack?

- Passive
  - Only detect and report the results
  - SNMP Traps
  - Logging and record creation
- Active
  - Response mechanism to the attacks
  - Close Connections: TCP RST
  - Perform system or operational modifications
  - Reconfiguration of routers, firewalls, ...

Classification

Detection Method	Misuse detection
	Anomaly Detection
Data Source	Network-based
	Host-based
Detection Delay	Real-time
	A posteriori
Reaction	Passive
	Active
Analysis	Individual
	Cooperative

Examples?

Examples

I. Network-based IDS

- Open-source
- Knowledge-based identification
- Usable as logger and real-time sniffer
- Custom rule / reaction definition
- Community signature updates

II. Host-based IDS

- Open-source
- Knowledge-based identification
- Multiple functionalities:
  - Log analysis
  - Integrity checks
  - Rootkit detection
  - Active response
  - ...
- Custom rule / reaction definition
- Release signature updates

Literature

- Denning, Dorothy E. *An intrusion-detection model.* IEEE Transactions on software engineering 2 (1987) 222-232.
- Kilic, Fatih, and Claudia Eckert. *iDeFEND: intrusion detection framework for encrypted network data.* International Conference on Cryptology and Network Security. Springer, Cham, 2015.
- Kim, Gisung, Seungmin Lee, and Sehun Kim. *A novel hybrid intrusion detection method integrating anomaly detection with misuse detection.* Expert Systems with Applications 41.4 (2014): 1690-1700.
- OSSEC, `https://www.ossec.net/`
- Provos, Niels. *A Virtual Honeypot Framework.* USENIX Security Symposium. Vol. 173. 2004.
- Snort, `https://snort.org/`
- Verwoerd, Theuns, and Ray Hunt. *Intrusion detection techniques and approaches.* Computer communications 25.15 (2002): 1356-1365.